

SolutionsHub Security Overview

A web application that captures new Amentum Solutions and Offerings, routes them through review and approval, and publishes the approved result. This note describes the architecture, the data it holds and how people sign in — prepared for IT and Cyber review.

DOCUMENT	DATE	STATUS
Security overview v1.0	10 September 2026	Development / pre-pilot
OWNER	HOSTING	
Darren Rourke	Microsoft Azure (PaaS)	

01 What we are asking you to review

SolutionsHub replaces a Microsoft Form plus manual email chasing with a single tracked process, from submission through review, approval and publication.

It is built entirely from Azure platform services in one resource group, and holds internal business content about Amentum offerings plus the work contact details of the people who own them. It stores no passwords and processes no payment data.

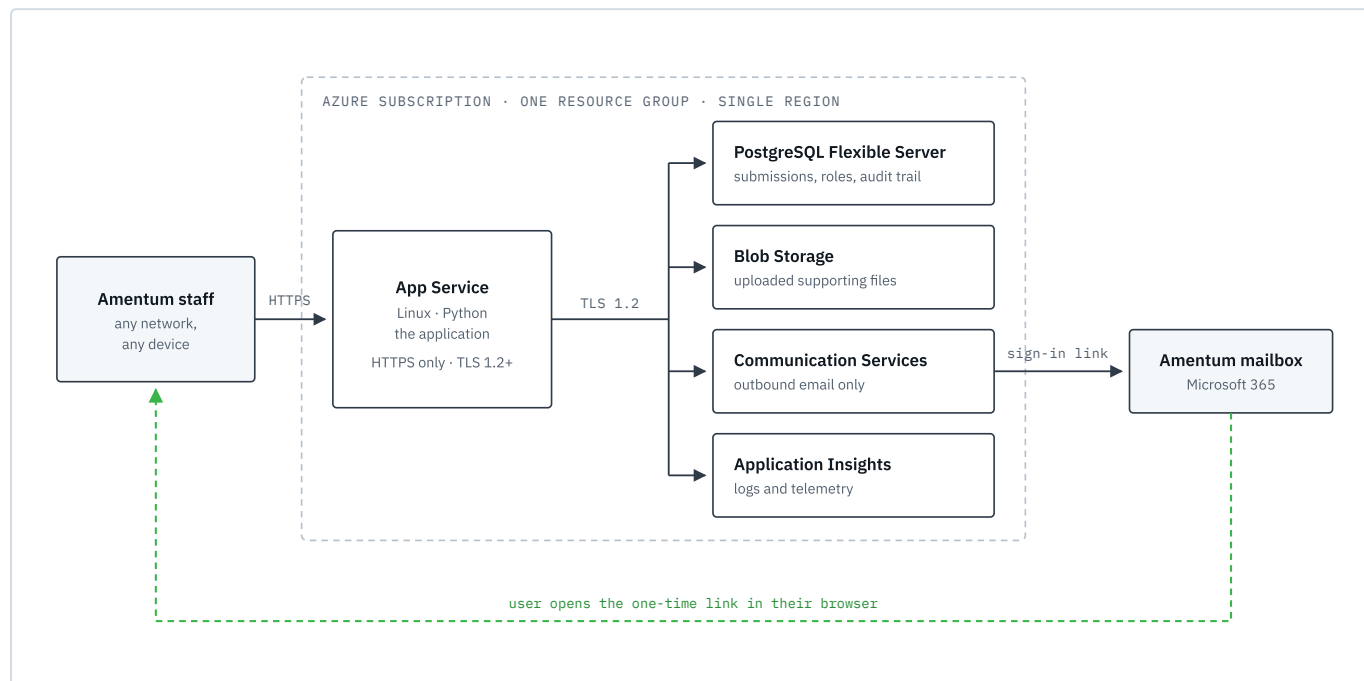
Two design decisions need your explicit agreement, and both are set out in full below: the application is reachable from the public internet with access controlled by identity rather than network location (§05), and it authenticates people by emailing a one-time link to an Amentum mailbox rather than through corporate SSO (§05), because its users sit across two unconnected domains.

Quick answers

Who can sign in? Only holders of an @amentum.com , @global.amentum.com or @amentumcms.com mailbox. No other address can obtain access.	Where does the data live? One Azure resource group in a single region. Nothing leaves Azure except outbound notification email.
Are passwords stored? No. The service is passwordless, so there are no password hashes to breach or reset.	Is there an audit trail? Yes. Every sign-in, approval and status change is written to an append-only table with actor, timestamp and source IP.
Third parties involved? Microsoft Azure only, plus GitHub for source control and deployment. No other processor.	Is data encrypted? TLS 1.2+ in transit everywhere; Azure platform encryption at rest on the database and file storage.
What is the blast radius? Internal marketing and capability content, plus names and work email addresses. No customer, classified or personal-sensitive data.	Can access be revoked? Immediately. An administrator disables the account, which kills every active session and blocks new sign-in links.

02 Architecture

Five managed Azure services in one resource group. There are no virtual machines to patch, no containers to maintain and no inbound connections from anywhere other than a user's browser.



Every inbound connection is a browser reaching the App Service over HTTPS. The four backing services are reachable only by the application, never directly by a user. The green path is the authentication loop: the sign-in link travels out by email and returns through the user's own browser — the mechanism described in §05.

AZURE SERVICE	ROLE IN THE SOLUTION	SECURITY POSTURE
App Service Linux, Python, B1 plan	Hosts the web application. The only component users reach.	HTTPS enforced, TLS 1.2 minimum, FTP disabled, HSTS and a strict Content Security Policy on every response.
PostgreSQL Flexible Server, Burstable	Submissions, role assignments, comments and the audit trail.	TLS required on every connection. Reachable only from Azure services, not the public internet. Point-in-time restore for 7 days.
Blob Storage StorageV2, LRS	Files attached to a submission.	Private container, anonymous access disabled. Files are served only through the application after a permission check. Soft delete 30 days, versioning on.
Communication Services Email	Sends sign-in links and workflow notifications.	Outbound only — it cannot receive mail and exposes no inbound surface.
Application Insights on Log Analytics	Errors, performance and availability monitoring.	Retained 30 days with a daily ingestion cap. Email addresses are kept in the audit table, not in telemetry.

Deployment

All infrastructure is defined as code (Azure Bicep) and deployed from GitHub Actions, so the running configuration is reviewable and reproducible. Lint, tests and a database migration check run on every change before it can deploy.

03 Data flow

A submission moves through seven stages — Submitted, Under Review, Updates Required, Awaiting Approval, Approved, Ready to Publish, Published. Each transition is checked against the user's role, written to the audit trail, and triggers an email to whoever owns the next action.

Data enters in one place, through the intake form. It leaves in two: notification email to Amentum mailboxes, and an export package the publishing team downloads when content is approved for publication.

Data inventory

DATA CATEGORY	CONTENTS	CLASSIFICATION	RETENTION
Offering content	Customer challenge, technical description, benefits, opportunity and contract values	Confidential	Life of the record
Contact details	Name, work email address and optional work telephone number of owners and reviewers	Internal (personal data)	Life of the record

DATA CATEGORY	CONTENTS	CLASSIFICATION	RETENTION
Uploaded attachments	Supporting documents provided by submitters. Limited to 10 files per submission, 25 MB each, permitted file types only.	Confidential (assumed)	Life of the record; deleted files recoverable for 30 days
Audit records	Actor, action, timestamp and source IP address for every sign-in and workflow transition	Internal	Life of the record
Notification log	Record of each email sent, including recipient address and delivery status	Internal	12 months
Sign-in tokens	SHA-256 hash of a one-time link. The link itself is never stored.	Restricted	15 minutes, then deleted

Classified against the standard four-tier scheme (Public, Internal, Confidential, Restricted). Please confirm the equivalent tiers in Amentum's own data classification policy and we will adopt that terminology.

Proposed usage boundary

SolutionsHub is intended for internal business and marketing content. We propose it is **not** approved for classified, export-controlled (ITAR/EAR) or personal-sensitive material, and that this is stated to users at the point of upload. We would welcome your wording.

The only personal data held is business contact information for Amentum employees, processed on legitimate interest for internal business administration. There is no special-category data and no customer personal data.

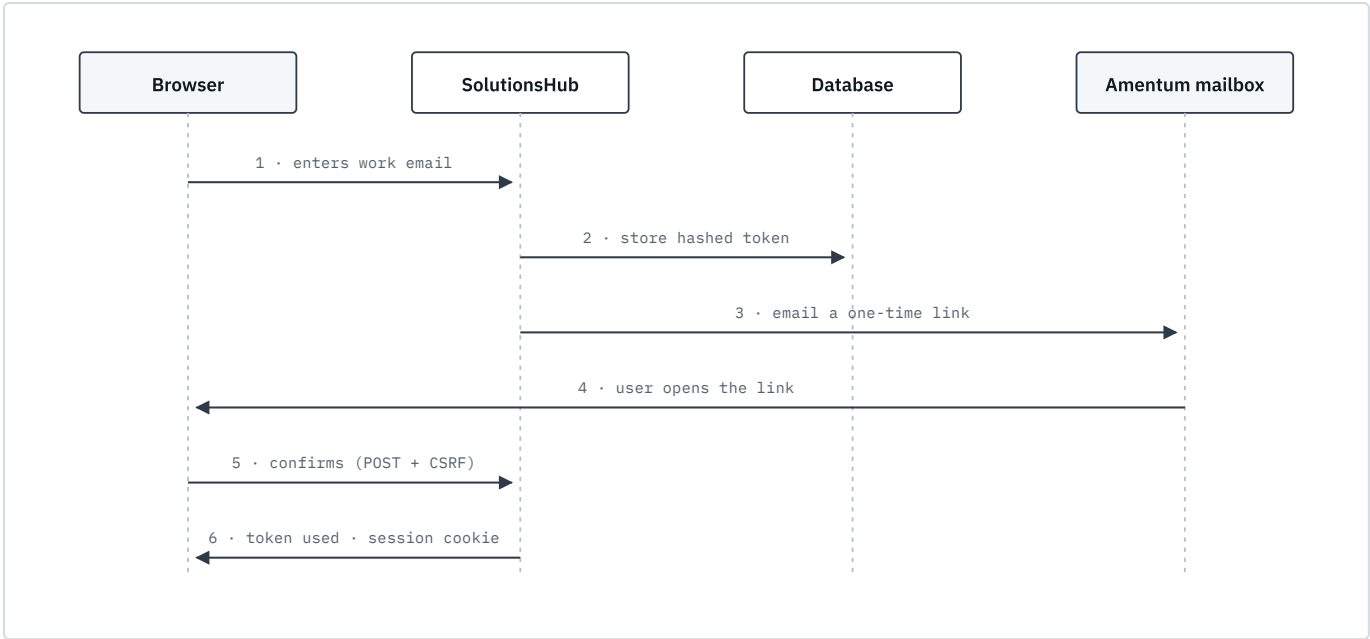
04 Why not corporate SSO

The intended users sit across two unconnected domains, so no single Entra ID tenant contains all of them. Federating the two is a much larger piece of work than this application justifies.

What both populations do share is an Amentum mailbox. The service therefore treats **control of an Amentum mailbox** as the proof of identity, which is the same assumption behind every corporate password-reset flow. If SSO becomes available across both domains, it can replace this mechanism without changing anything else in the design.

05 How sign-in works

There is no password. A user enters their work email, receives a one-time link, and confirms on the page that link opens.



Step 5 is deliberate. The link does not sign anyone in when it is merely fetched — it requires a form submission on the page it opens, so corporate link scanners that pre-fetch URLs cannot consume a user's token before they reach it.

Controls at each stage

CONTROL	SETTING
Accepted senders	Three Amentum domains only. Any other address receives an identical response and no email, so the form cannot be used to discover valid addresses.
Token strength	32 bytes from the operating system's cryptographic random source.
Token at rest	Only a SHA-256 hash is stored. A database compromise yields no usable links.
Token lifetime	15 minutes, single use, invalidated when a newer link is requested.
Request throttling	5 link requests per address per hour, 30 per source network, 10 failed confirmations per network.
Session cookie	Signed, HttpOnly, Secure, SameSite=Lax. Server-side record so it can be revoked.
Session lifetime	8 hours sliding, 24 hours absolute. Optional 30-day trusted device.
Revocation	Disabling a user kills all their sessions immediately and blocks new links.

Why the endpoint is public

Users on two unconnected domains, working from offices, home and client sites, cannot reliably share a single network path. Rather than depend on network location, the design places the control at identity.

Only four things are reachable without a session: the sign-in form, the link confirmation page, a health check that returns nothing but ok, and static CSS and images. Every other URL redirects to sign-in. An attacker who reaches the site without an Amentum mailbox can do exactly one thing — cause a sign-in email to be sent to an Amentum address, which is rate limited as above.

If you would prefer defence in depth, IP restrictions or Azure Front Door with WAF can be layered on top without any application change. We are happy to be directed here.

06 Who can do what

Signing in proves identity; it grants no privilege beyond submitting an offering and viewing approved content. Roles are held in the application and assigned by an administrator. Every check runs server-side on every request.

ROLE	CAN DO	ASSIGNED BY
Signed-in user	Submit an offering, browse approved content, edit their own submission before review.	Automatic on first sign-in
Reviewer	Validate submissions and request changes, optionally scoped to one business group.	Administrator
Approver	Approve or reject. Cannot approve an offering they own.	Administrator
Publisher	Prepare approved content and record publication.	Administrator
Administrator	Manage roles and reference data, disable users, read the audit log.	Existing administrator

- **Separation of duties** — nobody can approve their own offering, administrators included.
- **No self-elevation** — a user cannot grant themselves a role; both parties are named in the audit record.
- **First administrator** is set by configuration and only applies while no administrator exists.

07 Security controls

AREA	CONTROL
Transport	HTTPS enforced end to end, TLS 1.2 minimum, HSTS. TLS required on the database connection.
At rest	Azure platform encryption on database and file storage.
Browser hardening	Content Security Policy restricted to same-origin, X-Frame-Options: DENY, nosniff, Referrer and Permissions policies. No third-party scripts, trackers or fonts served to users.
Injection	Parameterised queries throughout an ORM; templates escape output by default.
Forgery	CSRF token on every state-changing request, plus SameSite cookies.
Uploads	Extension allowlist, size and count limits, sanitised filenames, stored under generated paths, always served as attachments and never executed or rendered inline.
Audit	Append-only record of sign-ins, transitions, approvals, role changes and exports, with actor, timestamp and IP. Exportable as CSV.
Backup	Database point-in-time restore 7 days; file soft delete 30 days with versioning.

AREA	CONTROL
Supply chain	Pinned dependencies, automated dependency scanning, all changes reviewed in GitHub before deployment.

08 Known gaps and decisions taken

Stated plainly so you are not asked to discover them. The first three are consequences of the current development-phase permissions and are already scheduled.

ITEM	POSITION	STATUS
Secrets in configuration	Service credentials sit in App Service configuration, encrypted at rest and visible only to those with write access to the app. Azure Key Vault was not used because creating the role assignments it needs requires permissions the project does not yet hold.	Planned
Service-to-service authentication	Components authenticate with keys and connection strings rather than managed identity, for the same permissions reason. No credential is in source control.	Planned
Sender domain	Email currently sends from an Azure-managed domain. A verified Amentum subdomain with SPF, DKIM and DMARC is required before pilot, both for deliverability and so recipients can see the mail is genuinely ours.	Before pilot
Database network exposure	The database accepts connections from Azure services and enforces TLS with a generated credential. Restricting to the application's outbound addresses, or private networking, is the hardening step.	Planned
Public endpoint	A deliberate decision, reasoned in §05. Reversible without application changes.	Decision
Email as identity proof	A deliberate decision, reasoned in §04. Anyone controlling an Amentum mailbox can sign in — the same assumption as corporate password reset.	Decision
No high availability	Single instance, single region. This is an internal productivity tool, not a service with an availability commitment.	Accepted

09 What we need from you

- Agreement on the two design decisions in §05 and §04 — the public endpoint and email-based identity — or direction to change them.
- Confirmation of the usage boundary in §03, and your preferred wording to show users at upload.
- A DNS record change to create a verified sending subdomain, so notification email is demonstrably from Amentum. We can supply the exact records; no change to any existing domain is required.
- Any additional logging, retention or review requirements you need before pilot.

Happy to walk through the code, the infrastructure definition or a live demonstration at whatever depth is useful. A three-minute recorded walkthrough of the full submit-to-publish journey is available on request.